GRC (GOVERNANCE, RISK MANAGEMENT AND COMPLIANCE)

HARSHIT BHARDWAJ

INFORMATION SECURITY GOVERNANCE

- Information security governance represents an organisation's established structure, policies, methods, and guidelines designed to guarantee the privacy, reliability, and accessibility of its information assets.

INFORMATION SECURITY GOVERNANCE

- It is essential for risk management, safeguarding confidential data from unauthorised intrusion, and adhering to pertinent regulations. Information security governance falls under the purview of top-tier management and includes the following processes:

- **Strategy:** Developing and implementing a comprehensive information security strategy that aligns with the organisation's overall business objectives.

- **Policies and procedures:** Preparing policies and procedures that govern the use and protection of information assets.

INFORMATION SECURITY GOVERNANCE

- **Risk management:** Conduct risk assessments to identify potential threats to the organisation's information assets and implement risk mitigation measures.
- **Performance measurement:** Establishing metrics and key performance indicators (KPIs) to measure the effectiveness of the information security governance program.
- **Compliance:** Ensuring compliance with relevant regulations and industry best practices.

INFORMATION SECURITY REGULATION

Governance and regulation are closely linked in the information security paradigm but have distinct meanings. Information security regulation refers to legal and regulatory frameworks that govern the use and protection of information assets. Regulations are designed to protect sensitive data from unauthorized access, theft, and misuse.

Compliance with regulations is typically mandatory and enforced by government agencies or other regulatory bodies. Examples of information security regulations/standards include the General Data Protection Regulation (GDPR), Payment Card Industry Data Security Standard (PCI DSS) and many more.

KEY BENIFITS

Enhanced Security Posture: Reduces security risks and protects sensitive data through comprehensive governance and regulatory compliance.

Increased Stakeholder Confidence: Builds trust by showcasing a commitment to cybersecurity.

Regulatory Compliance: Avoids legal, financial penalties, and reputational damage from non-compliance with regulations like GDPR, HIPAA, or PCI DSS.



KEY BENIFITS

- **Alignment with Business Goals:** Integrates security strategies with business objectives, ensuring cost-effectiveness and success.
- **Informed Decision-Making:** Empowers leaders to address risks and prioritize necessary security measures.
- **Competitive Edge:** Highlights dedication to data protection, boosting stakeholder trust and market position.

INFORMATION SECURITY FRAMEWORKS

- The information security framework provides a comprehensive set of documents that outline the organisation's approach to information security and governs how security is implemented, managed, and enforced within the organisation. This mainly includes:
- **Policies:** A formal statement that outlines an organisation's goals, principles, and guidelines for achieving specific objectives.
- **Standards:** A document establishing specific requirements or specifications for a particular process, product, or service.

INFORMATION SECURITY FRAMEWORKS

- **Guidelines:** A document that provides recommendations and best practices (non-mandatory) for achieving specific goals or objectives.

- **Procedures:** Set of specific steps for undertaking a particular task or process.

- **Baselines:** A set of minimum security standards or requirements that an organisation or system must meet

DEVELOPING GOVERNANCE DOCUMENTS

Steps to Develop Policies, Standards, and Guidelines

Define Scope and Purpose: Determine what the document covers and its necessity.

Research: Review laws, regulations, standards, and existing documents for relevance and consistency.

Draft: Create a clear, actionable document aligned with organizational goals.



Identify the scope and purpose



Research and review



Draft the document



Review and approval



Implementation and communication



Review and update

DEVELOPING GOVERNANCE DOCUMENTS

Review and Approve: Seek feedback from stakeholders and finalize with proper approvals.

Implement: Communicate, train, and ensure understanding among stakeholders.

Maintain: Periodically review, update, and adjust based on feedback and changes.

EXAMPLES USING REAL-WORLD SCENARIOS

Creating an Acceptable Use Policy (AUP):

- **Define Usage Rules:** Specify acceptable activities, such as work-related tasks, and prohibited activities, like accessing illegal or inappropriate content.
- **Identify Monitoring Measures:** Explain how user activity will be monitored and under what circumstances.
- **Specify Consequences:** Define repercussions for violating the policy.
- **Communicate the Policy:** Ensure all employees acknowledge and understand the policy.
- **Review and Update:** Periodically update based on changes in technology or legal requirements.

EXAMPLES USING REAL-WORLD SCENARIOS

Preparing a Password Policy:

- **Define password requirements:** Minimum length, complexity, and expiration.
- **Define password usage guidelines:** Specify how passwords should be used, such as requiring unique passwords for each account, prohibiting the sharing of passwords, and prohibiting default passwords.
- **Define password storage and transmission guidelines:** Using encryption for password storage and requiring secure connections for password transmission.
- **Define password change and reset guidelines:** How often passwords should be changed etc.

EXAMPLES USING REAL-WORLD SCENARIOS

- **Communicate the policy:** Communicate the password policy to all relevant employees and stakeholders, and ensure that they understand the requirements and guidelines. Develop training and awareness programs to ensure that employees follow the policy.
- **Monitor compliance:** Monitor compliance with the password policy and adjust the policy as needed based on feedback and changes in the threat landscape or regulatory environment.

WHAT DOES GRC STAND FOR?

- **Governance:** Set of rules, policies and operations that a company uses to achieve its business goals.

- **Risk Management:** Risk management helps businesses identify risks and find ways to remediate any that are found.

- **Compliance:** Compliance is the act of following rules, laws, and regulations.


Governance
It is the rules, processes and policies to steer the organisation
Risk Management
Risk refers to day-to-day technical processes to mitigate the risk
Compliance
Steps taken to meet standards and run legally

- To combat the evolving threats, a comprehensive approach to **information security governance & regulation** is necessary.

- Such an approach requires establishing robust policies and guidelines and implementing rigorous monitoring and enforcement mechanisms to ensure compliance.

DEVELOPING GRC PROGRAM

- A well-developed and implemented GRC program for cyber security provides an integrated framework for managing risks, complying with regulations and standards, and improving the overall security perspective of an organisation. It enables effective governance, risk management, and compliance activities, mitigating cyber incidents' impact and ensuring business resilience.

DEVELOPING GRC PROGRAM

Steps to Implement a GRC Program

- **Define Scope and Objectives:** Set program goals, e.g., reducing cyber risks by 50% within 12 months.
- **Conduct Risk Assessment:** Identify and prioritize risks, such as weak access controls or outdated software.
- **Develop Policies:** Create guidelines, e.g., strong password policies and system access monitoring.
- **Establish Governance:** Form committees, define roles, and set processes for managing security risks.
- **Implement Controls:** Deploy firewalls, SIEM, IPS, IDS, and conduct employee training to mitigate risks.

DEVELOPING GRC PROGRAM

- **Monitor Performance:** Track metrics, compliance, and adjust the program as needed.
- **Continuous Improvement:** Review and refine based on incidents, metrics, and feedback.

GRC FRAMEWORK IN FINANCIAL SECTOR

- **Governance-Related Activities:** Nominate the governance level executives, and make financial-related policies such as bank secrecy act, anti-money laundering policy, financial audit policies, financial reporting, crisis management, and many more.

- **Risk Management Activities:** Identify potential risks, their possible outcomes, and countermeasures such as financial fraud risks, fraudulent transactions through cyber-attack, stolen credentials through phishing, fake ATM cards, etc.

GRC FRAMEWORK IN FINANCIAL SECTOR

- **Compliance Activities:** Take measures to meet legal requirements and industry standards such as PCI DSS, GLBA, etc. Moreover, this also includes implementing correct methods like SSL/ TLS to avoid Man in the Middle (MITM) attacks, ensuring automatic patch management against unpatched software, creating awareness campaigns for users to protect them from phishing attacks, and many more.

STANDARD

- **Definition:** A defined set of rules, controls, or best practices to ensure uniformity in operations and security.

- **Purpose in GRC:** Standards ensure adherence to industry-recognized benchmarks, fostering trust and improving compliance efforts.

Examples in GRC:

- **ISO 27001:** Information Security Management System (ISMS).
- **PCI DSS:** Ensures secure payment card transactions.

REGULATION

- **Definition:** Legally binding rules enforced by governments or authorities to ensure compliance with laws.
- **Purpose in GRC:** Regulations ensure organizations operate within the legal framework, protecting stakeholders and minimizing risks.

Examples in GRC:

- **GDPR:** Regulates personal data protection in the EU.
- **HIPAA:** Protects healthcare information in the U.S.

POLICY

- **Definition:** Internal directives set by an organization to regulate behavior, processes, and security measures.
- **Purpose in GRC:** Policies align internal practices with legal, regulatory, and organizational requirements.

Examples in GRC:

- **Access Control Policy:** Manages user access to sensitive systems.
- **Incident Response Policy:** Guides how to handle security incidents.

GUIDELINE

- **Definition:** Non-mandatory recommendations that suggest best practices for achieving compliance and minimizing risks.
- **Purpose in GRC:** Guidelines supplement policies and frameworks by providing practical advice for implementation.

Examples in GRC:

- **NIST Password Guidelines:** Secure password management.
- **OWASP Top 10:** Identifying common web application vulnerabilities.

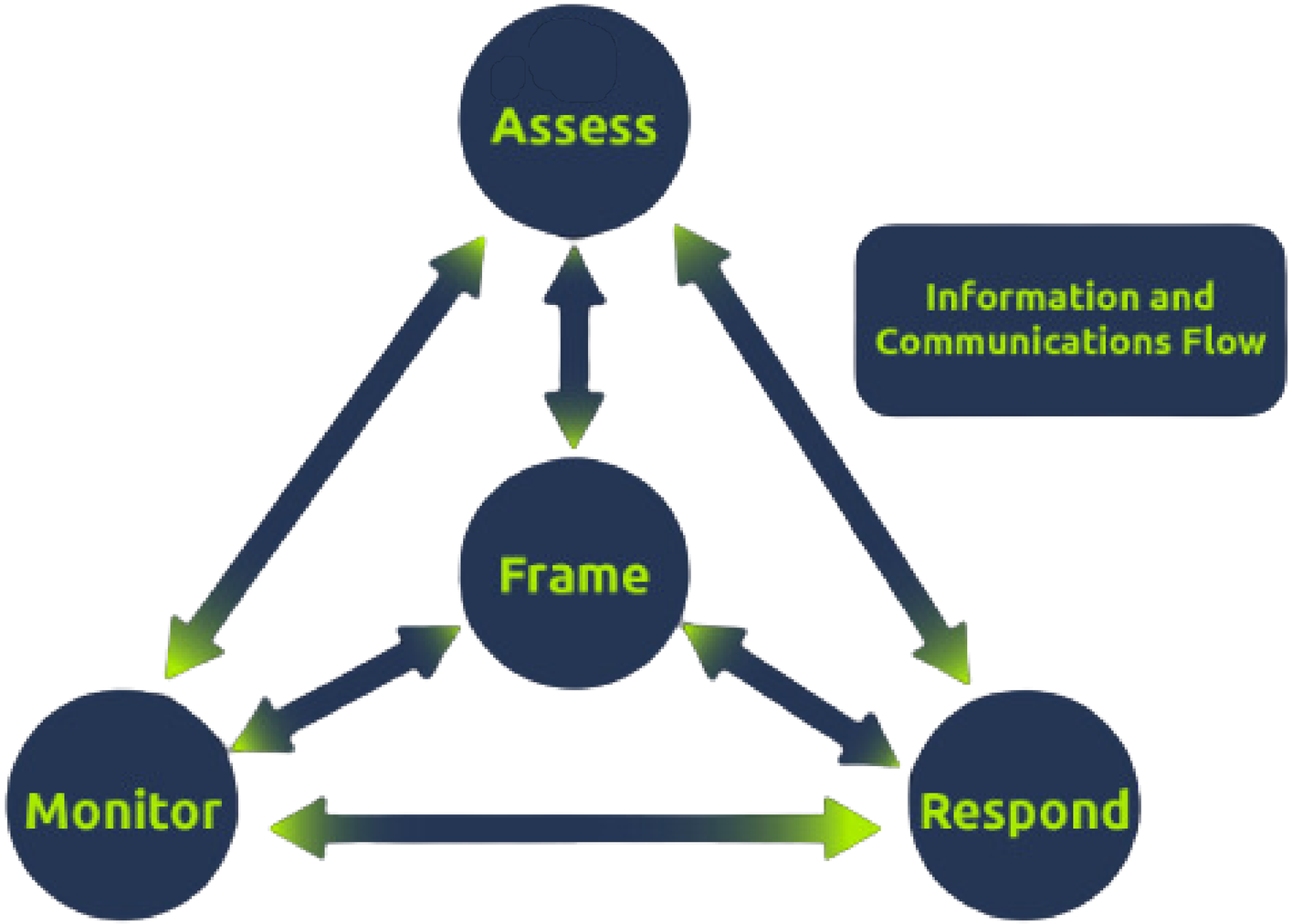
LAW

- **Definition:** Broad legal systems governing societal or organizational behavior, often encompassing multiple regulations.
- **Purpose in GRC:** Laws establish mandatory baselines for acceptable practices and liability.

Examples in GRC:

- **Cybersecurity Laws:** Mandates for protecting critical infrastructure.
- **Data Protection Laws:** CCPA in California for personal data protection.

RISK MANAGEMENT



RISK MANAGEMENT

- **Threats:** What are the threats that you need to consider?
- **Vulnerabilities:** What are the vulnerabilities that you have to deal with?
- **Impact:** What would be the impact if a threat exploited a vulnerability?
- **Likelihood:** What is the likelihood of this vulnerability being exploited?

RISK MANAGEMENT

- **Let's consider the following example for assessing one natural threat, a tsunami.** The company's main office is at ground level and overlooks the beach. That would make it vulnerable to tsunamis that can literally wash every single piece of equipment and paper inside the office. However, the country has never experienced tsunamis in its entire written history, and geologists state that the probability of a tsunami happening is negligible. In this scenario, we have:

- **Threat:** Tsunami
- **Vulnerability:** The office is near the seashore
- **Impact:** Destruction of office equipment
- **Likelihood:** Negligible

RISK MANAGEMENT

- An academic institution provides quality education through its undergraduate and graduate programs. While their research holds no monetary value, they are still vulnerable to ransomware attacks. Threat actors could encrypt their data and demand payment, disrupting operations until backups (if available) restore the data. Given the university's prestige, the likelihood of such an attack is high.

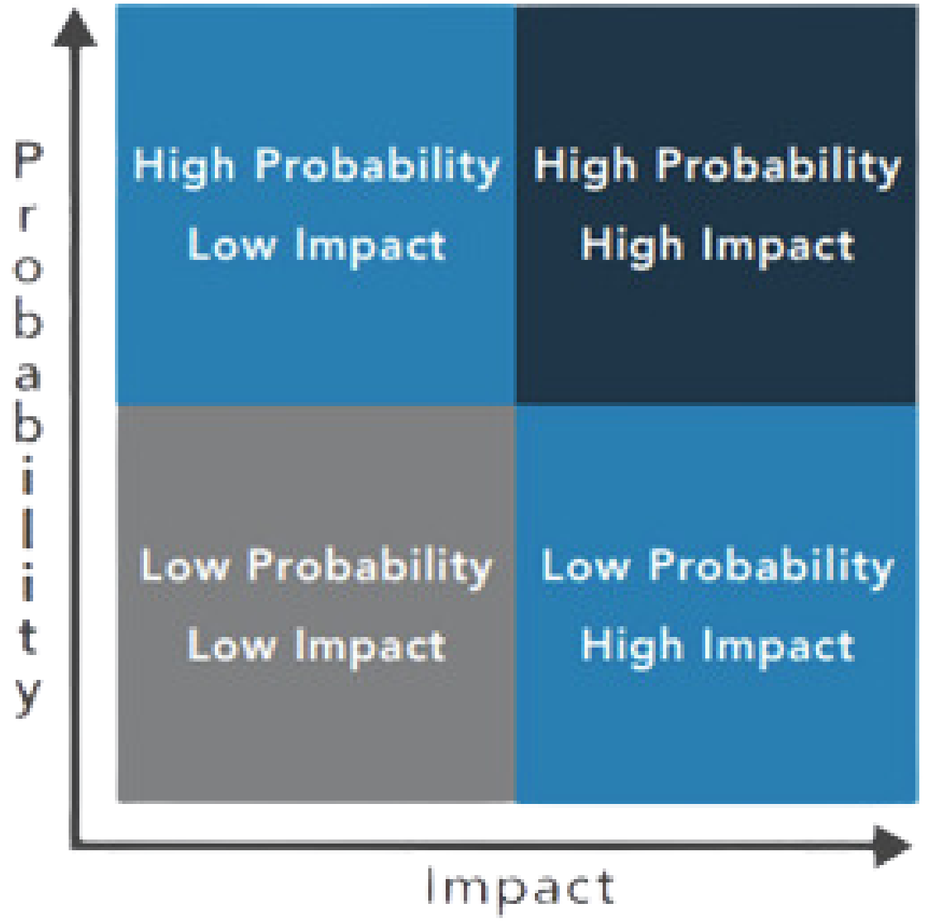
- **Threat:** Ransomware Groups
- **Vulnerability:** Data stored on computer systems
- **Impact:** Disruption to faculty and staff operations until data recovery
- **Likelihood:** High

RISK MANAGEMENT

Risk Analysis:

- **Qualitative Risk Analysis,** where we assign ratings to risks. The ratings can be a qualitative adjective, such as high, medium, and low. Alternatively, it can be something symbolic, such as red, yellow, and green.
- **Quantitative Risk Analysis,** where we assign monetary values and use that as a basis for decision-making.

QUALITATIVE RISK ANALYSIS



		Impact				
		Trivial	Minor	Moderate	Major	Extreme
Probability	Rare	Low	Low	Low	Medium	Medium
	Unlikely	Low	Low	Medium	Medium	Medium
	Moderate	Low	Medium	Medium	Medium	High
	Likely	Medium	Medium	Medium	High	High
	Very Likely	Medium	Medium	High	High	High

QUALITATIVE RISK ANALYSIS

As the name suggests, qualitative risk analysis uses qualitative adjectives to describe:

- **Probability** of a risk-taking place, i.e., probability of a threat exploiting a vulnerability
- **Impact** of the risk, if realised, which can range between trivial to extreme

QUANTITATIVE RISK ANALYSIS

Quantitative Risk Analysis involves the use of numerical and statistical methods to assess and prioritize risks by determining their potential impact in measurable terms, typically financial loss or downtime. This method provides a data-driven approach for decision-making in risk management.

QUANTITATIVE RISK ANALYSIS

- **Asset Value (AV):** $100,000 (a database)
- **Exposure Factor (EF):** 30% (data breach affects 30% of database value)
- **Single Loss Expectancy (SLE):**

$$SLE = 100,000 \times 0.3 = 30,000$$

- **Annualized Rate of Occurrence (ARO):** 2 (breach expected twice a year)
- **Annualized Loss Expectancy (ALE):**

$$ALE = 30,000 \times 2 = 60,000$$

If implementing a $25,000 safeguard reduces the ARO to 0.5, the new ALE would be:

$$ALE = 30,000 \times 0.5 = 15,000$$

The cost-benefit analysis would justify the safeguard since it reduces losses.

MONITOR RISK

We have assessed the risk and responded with a proper measure; what's next? We need to keep monitoring risks. Many reasons dictate that we continue to monitor risk, even after an appropriate response has been implemented. The reasons include the following:

- Finding and adding new risks
- Eliminating risks that are no longer relevant
- Assessing our responses to existing risks

COMPLIANCE

Compliance refers to an organization’s adherence to laws, regulations, standards, and internal policies to meet legal, ethical, and operational requirements. It ensures the organization operates within the defined rules while minimizing risks and avoiding penalties.

LEGAL COMPLIANCE

Definition: Adhering to laws and regulations set by governments.

Example:

- **GDPR:** Protects personal data of EU citizens, requiring consent and secure storage.
- **HIPAA:** Protects healthcare data in the U.S., ensuring patient confidentiality.

Importance: Prevents legal penalties and builds trust with customers.

REGULATORY COMPLIANCE

Definition: Adhering to industry-specific regulations.

Example:

- **PCI DSS:** Secures payment card transactions by enforcing encryption and access controls.
- **AML:** Banks prevent money laundering through customer verification and transaction monitoring.

Importance: Ensures industry standards and protects consumers.

INTERNAL COMPLIANCE

Definition: Following an organization's internal policies and procedures.

Example:

- **Password Policy:** Enforces password complexity and periodic changes to ensure system security.
- **Whistleblower Policy:** Allows employees to report unethical behavior.

Importance: Maintains security and ethical practices within the organization.

CONTRACTUAL COMPLIANCE

Definition: Meeting obligations outlined in contracts with external parties.

Example:

- **SLAs:** Service providers must meet performance standards like uptime and response time.
- **Vendor Contracts:** Suppliers must meet delivery and quality standards.

Importance: Prevents legal disputes and ensures agreed-upon terms are met.

EXAMPLES OF COMPLIANCE REQUIREMENTS

- **GDPR:** For data protection and privacy in the EU.
- **SOX:** For financial transparency and accounting practices.
- **ISO 27001:** For information security management.
- **HIPAA:** For healthcare data protection in the U.S.

PRIVACY AND DATA PROTECTION

In every sector, such as financial, healthcare, government, and industry, privacy and data protection regulations are critical as they deal with citizens' **Personally Identifiable Information (PII)**. Privacy regulations help ensure individuals' personal information is handled and stored responsibly and ethically. They also help to establish trust, protect personal information, and maintain regulatory compliance.

INTRODUCTION TO PII



- Information that identifies an individual directly or indirectly.
- Includes name, Adhaar Card, address, phone number, and email.
- Safeguarding PII prevents identity theft and ensures privacy.

TYPES OF PII

- **Sensitive PII :** Data such as biometrics, financial information, or health records.
- **Non-sensitive PII :** Publicly available information like an email address or phone number.

DIGITAL PERSONAL DATA PRIVACY ACT, 2023



- **Overview:** The Act regulates the collection, processing, and storage of personal data to protect privacy and enhance accountability.

- **Focus:** Empowering individuals while ensuring companies meet compliance standards.

RIGHTS OF DATA PRINCIPALS (INDIVIDUALS)

- **Right to Access :** Individuals can review the data collected about them.

- **Right to Correction/Deletion :** Fix inaccuracies or delete data when no longer needed.

- **Right to Grievance Redressal :** Seek action through the Data Protection Board for violations.

DATA PRINCIPALS

- **Fundamental guidelines ensuring ethical and legal management of personal data**

- **Core Principles:**
- Lawfulness, Fairness, Transparency: Clear and lawful collection and usage of data.
- Purpose Limitation: Data used only for specific, legitimate purposes.
- Data Minimization: Only collect necessary data.
- Accuracy & Storage Limitation: Keep data accurate and for the required time only.
- Integrity & Accountability: Ensure data protection and compliance with regulations.

DATA FIDUCIARY

- **Data Fiduciary:** An entity that manages and protects personal data on behalf of another, with a legal obligation to act in the best interest of the data Principle.

Key Responsibilities:

- Protecting data privacy and security
- Compliance with laws
- Ensuring transparency and accountability

DATA PROCESSOR

- **An entity that processes personal data on behalf of a data controller, following their instructions.**

Core Responsibilities:

- Execute data processing under the controller's guidance.
- Ensure data protection through proper security measures.
- Ensure compliance with data laws and regulations.
- Engage sub-processors with proper agreements.

DATA PROCESSOR

- **An entity that processes personal data on behalf of a data controller, following their instructions.**

Core Responsibilities:

- Execute data processing under the controller's guidance.
- Ensure data protection through proper security measures.
- Ensure compliance with data laws and regulations.
- Engage sub-processors with proper agreements.

INFORMATION ASSETS



Personal information



Budgets



Physical



Customer Records



Business Plans



Financial and Contractual

THE CONTROLS

ORGANIZATIONAL CONTROLS	PEOPLE CONTROL
PHYSICAL CONTROL	TECHNOLOGICAL CONTROL

QUESTIONS?



THANK YOU!

Harshit Bhardwaj